

Task 17 | Password Cracking

TechBiz Academy | Mah Noor

Prepared by	Mah Noor	
Program	TechBiz Academy - Ethical Hacking Internship	
Track	UBI Ethical Hacking Advanced Track	
Candidate ID	TBS-2026-242	Cohort 2
Week	Week 6	
Date	September 27, 2026	

1. Objective

The objective of this task was to understand password hashing concepts (MD5, SHA-256, bcrypt), create sample hashes, and crack them using John the Ripper with a wordlist attack using rockyou.txt. The task also covers the key difference between hashing and encryption.

2. Key Concepts

What is Hashing?

Hashing is a one-way process that converts input data into a fixed-length string using a mathematical algorithm. It is NOT reversible - you cannot convert a hash back to the original password directly.

- ▶ MD5: 128-bit hash, fast but weak - vulnerable to collision attacks.
- ▶ SHA-256: 256-bit hash, significantly stronger than MD5.
- ▶ bcrypt: Slow, salted hash - specifically designed for secure password storage.

Hashing vs Encryption

Feature	Hashing	Encryption
Direction	One-way (irreversible)	Two-way (reversible with key)
Purpose	Verify integrity / store passwords	Protect data in transit or storage
Key Required	No	Yes
Algorithms	MD5, SHA-256, bcrypt	AES, RSA, 3DES
Output	Fixed-length hash	Variable-length ciphertext

3. Tool - John the Ripper

John the Ripper is a free, open-source password auditing and recovery tool pre-installed in Kali Linux. It supports hundreds of hash types and multiple attack modes.

- ▶ Wordlist Attack: Tries every word from rockyou.txt against the hash.
- ▶ Brute Force Attack: Tries all possible character combinations exhaustively.
- ▶ Rule-based Attack: Applies mutation rules (l33tspeak, capitalization) to wordlist entries.

4. Practical Steps

Step 1 - Create Sample MD5 Hashes

Generated MD5 hashes for two sample passwords using the Kali Linux terminal, saved them to hash.txt, and launched a wordlist attack using John the Ripper with the Raw-MD5 format:

```
(mahnoor@kali)-[~/Desktop]
$ echo -n 'password' | md5sum
5f4dcc3b5aa765d61d8327deb882cf99 -

(mahnoor@kali)-[~/Desktop]
$ echo -n '123456' | md5sum
e10adc3949ba59abbe56e057f20f883e -

(mahnoor@kali)-[~/Desktop]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
stat: hash.txt: No such file or directory

(mahnoor@kali)-[~/Desktop]
$ echo "5f4dcc3b5aa765d61d8327deb882cf99" > hash.txt
echo "e10adc3949ba59abbe56e057f20f883e" >> hash.txt
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Warning: detected hash type "LM", but the string is also recognized as "dynamic-md5($p)"
Use the "--format=dynamic-md5($p)" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "HAVAL-128-4"
Use the "--format=HAVAL-128-4" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "MD2"
Use the "--format=MD2" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "mdc2"
Use the "--format=mdc2" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "mscash"
Use the "--format=mscash" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "mscash2"
Use the "--format=mscash2" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "NT"
Use the "--format=NT" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD4"
Use the "--format=Raw-MD4" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD5"
```

Figure 1 - Kali Linux: MD5 hashes generated and John the Ripper wordlist attack launched

Step 2 - Cracking Results & Verification

John the Ripper successfully cracked both MD5 hashes in under one second, as shown in the terminal output below:

```
(mahnoor@kali)-[~/Desktop]
$ john --format=Raw-MD5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 2 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
123456 (?)
password (?)
2g 0:00:00:00 DONE (2026-09-27 04:40) 200.0g/s 38400p/s 38400c/s 76800C/s 123456..michael1
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

Figure 2 - Kali Linux: John the Ripper cracked both hashes successfully (123456 and password)

Step 3 - Hashing vs Encryption (Key Observation)

During this task, the practical difference between hashing and encryption was clearly observed. MD5 hashes that were "one-way" by design were still cracked instantly because rockyou.txt contained the exact plaintext passwords. This confirms: hashing alone is NOT sufficient security. Salting and using modern algorithms like bcrypt is mandatory for secure password storage.

5. Results Summary

Hash (MD5)	Cracked Password	Tool	Wordlist	Time
5f4dcc3b5aa765d61d8327deb882cf99	password	John the Ripper	rockyou.txt	< 1 sec
e10adc3949ba59abbe56e057f20f883e	123456	John the Ripper	rockyou.txt	< 1 sec

6. TryHackMe Room Completed

The following compulsory, free-tier TryHackMe room was completed as required for this task:

Crack the Hash ✓

Status: Completed | Tasks: 2 completed | Points Earned: 270 |

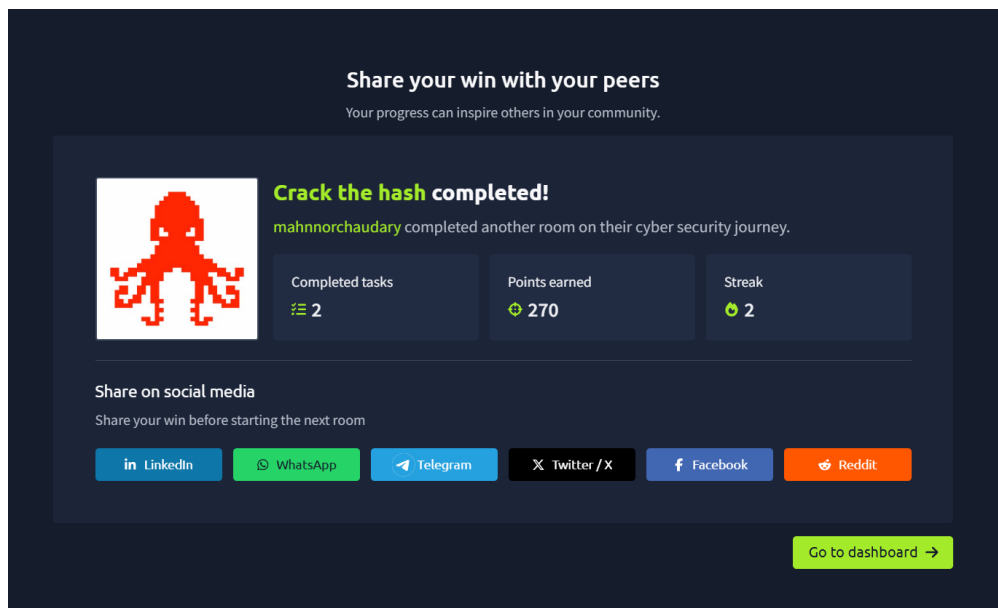


Figure 3 - TryHackMe: "Crack the Hash" room completion proof

7. Defense Against Password Cracking

Based on the findings of this task, the following security measures are strongly recommended:

- ✓ Use strong, long passwords (12+ characters with symbols, numbers, and uppercase letters).
- ✓ Always hash passwords with bcrypt or Argon2 - never use MD5 or SHA-1 for password storage.
- ✓ Add a unique random salt to each password before hashing to prevent rainbow table attacks.
- ✓ Implement account lockout policies after multiple failed login attempts.
- ✓ Enforce multi-factor authentication (MFA) wherever possible.
- ✓ Regularly audit and enforce strong password policies across all systems.
- ✓ Monitor login attempts and alert on anomalous brute-force patterns.

8. Conclusion

This task demonstrated how easily weak passwords can be cracked when stored as unsalted MD5 hashes. Using John the Ripper with the rockyou.txt wordlist, both "password" and "123456" were cracked in under one second. This highlights the critical importance of using modern, slow, salted hashing algorithms like bcrypt for password storage, and enforcing strong password policies across all systems.

The completion of the TryHackMe "Crack the Hash" room further reinforced practical hash-cracking skills in a controlled, legal lab environment - directly applicable to real-world penetration testing and security auditing scenarios.